

S19 Comparison with ISO 27005, NIST RMF, and NIST CSF

Purpose

This supplementary section positions HIM5-CDI relative to established cybersecurity risk management frameworks and highlights the framework's novel governance and CTI integration capabilities.

Comparative Analysis

Feature	ISO 27005:2022	NIST RMF (SP 800-37 Rev. 2)	NIST CSF 2.0	HIMS-CDI
Scope	General information security risk management	Federal IT systems	Critical infrastructure cybersecurity	Healthcare CTI-driven cybersecurity risk assessment
Explicit CTI Integration	Optional	Limited	Limited	Yes
Multi-Constraint Governance	Qualitative likelihood × impact	Control lifecycle management	Profiles and maturity tiers	Numeric non-compensatory governance gates
Clause-Level Regulatory Mapping	General ISO alignment	NIST SP 800-53 mapping	Control references	Machine-readable clause-level mappings
Edge-Deployment Feasibility	Not addressed	Not addressed	Not addressed	Explicit latency and memory constraints
Explainability Requirements	Not prescriptive	Not prescriptive	Not prescriptive	SHAP, traceability, and usability requirements
Machine-Readable Evidence Package	Not defined	Document-oriented SSP	Not defined	JSON-based ETP
Primary Audience	Risk managers	System owners and authorising officials	Broad organisational audience	Clinical safety and healthcare cybersecurity stakeholders

Conclusion

HIMS-CDI complements existing frameworks by incorporating structured CTI integration, clause-level regulatory traceability, deployment-feasibility constraints, and machine-readable auditability. Rather than replacing ISO 27005 or NIST RMF, the framework introduces a healthcare-oriented AI governance layer that can integrate with existing enterprise cybersecurity risk-management processes.